

COMPLIANCE REQUIREMENTS DOCUMENT

HIPAA & SOC 2 — CareFlow Platform

Document ID: COMP-MC-2026-006 | Version: 1.0 | Author: James Okafor (Security Lead) | Date: June 4, 2026

1. Regulatory Framework

CareFlow processes Protected Health Information (PHI) as defined under HIPAA (45 CFR Parts 160 and 164). MediConnect is a Covered Entity. Stackular Technologies acts as a Business Associate. BAAs must be in place with all sub-processors handling PHI before any PHI flows through those systems. CareFlow will also pursue SOC 2 Type II certification within 15 months of go-live.

2. HIPAA Security Rule Requirements (45 CFR s164.312)

Control	Specification	CareFlow Implementation
Access Control	Unique user ID, auto-logout, encryption	RBAC + per-user accounts + 15-min timeout + AES-256
Audit Controls	Record and examine activity in PHI systems	Elasticsearch write-once audit log for all PHI access
Integrity	Protect ePHI from improper alteration	SHA-256 checksums; immutable audit log
Person Authentication	Verify identity before granting access	Email/password + TOTP MFA for all clinical roles
Transmission Security	Protect ePHI over networks	TLS 1.3 for all transmissions; no plaintext allowed
Facility Access	Physical safeguards for systems	AWS data centres (SOC 2, ISO 27001 certified)

3. Required BAAs

Sub-processor	PHI Exposure	BAA Status	Deadline
AWS	PHI in RDS, S3, ElastiCache	Included in Enterprise Agreement	Already executed
Twilio (Video + SMS)	Telehealth metadata + reminder content	Twilio HIPAA BAA addendum required	Must execute by Week 7
SendGrid	Email notifications (limited PHI)	SendGrid HIPAA-compliant plan + BAA	Must execute by Week 7
Datadog	Logs may contain PHI if unfiltered	Datadog HIPAA BAA required	Must execute by Week 10

4. Data Residency Requirements

All PHI must remain on US soil at all times. Primary: AWS us-west-2. DR only: us-east-1. CloudFront configured with geo-restriction to US. No PHI may be cached at CDN edge nodes. Datadog log forwarding must route to US endpoints only.

5. SOC 2 Trust Service Criteria (Target)

Criterion	Requirement	Target Date
Security (CC)	Logical and physical access controls; change management	Audit kickoff Month 3 post-launch
Availability (A)	99.9% uptime SLA; monitoring; incident response	Week 8
Confidentiality (C)	PHI encryption; access controls; BAAs	Go-live
Processing Integrity (PI)	Complete and accurate processing; error handling	Week 12
Privacy (P)	Notice; consent; collection; retention; disposal	Week 16